CROWDSTRIKE

White Paper

Securing Browser Identity in the Modern Threat Landscape

Table of Contents

In This White Paper	3
The Role of Browser Identity in Digital Trust	4
The Modern Threat Landscape: 12 Techniques Targeting Browser Identity	4
Why Legacy Security Tools Fall Short	7
A New Approach: Browser-Native Security with Falcon Seraphic Enterprise Browser	9
Tangible Business Benefits	10
Next Steps	11

In this White Paper

The average number of SaaS applications deployed per company has grown to 101,[1] creating a "browser-first" work environment where employees now perform all or most of their work within a browser. As the primary interface for user productivity, modern web browsers have now become a central target for identity-based attacks. Sophisticated threat actors exploit browser trust models, session mechanisms, and authentication workflows to hijack sessions, steal credentials, and bypass multifactor authentication (MFA).

Traditional security architectures, focused on networks, struggle to detect or prevent these browser-native attacks.

This white paper explores the nature of these evolving threats, evaluates why legacy defenses are insufficient, and introduces a modern, browser-native approach to identity protection. CrowdStrike Falcon® Seraphic® Enterprise Browser provides the security you need, delivering visibility, control, and protection at the browser layer, where attacks typically unfold.

[1] Okta, Businesses at Work 2025

The Role of Browser Identity in Digital Trust

In today's enterprise, browsers are the gateway to cloud services, SaaS platforms, and identity providers. Browser identity refers to the set of digital artifacts — such as cookies, tokens, and session data — that authenticate and maintain a user's connection to online services. These artifacts, while essential for seamless access, are increasingly targeted by attackers due to their high value and relatively low protection within standard browsers.

Stolen browser artifacts can allow adversaries to bypass traditional security controls, including MFA and SSL VPNs, granting direct access to corporate applications and sensitive data. The rise of techniques like session hijacking, token theft, and Adversary-in-the-Browser (AiTB) or Man-in-the-Browser (MiTB) attacks underscores the need for security strategies that extend beyond network and endpoint defenses, placing greater emphasis on securing the browser itself and the identities it manages.

The Modern Threat Landscape: 12 Techniques Targeting Browser Identity

Over the past decade, the cyber threat landscape has undergone a dramatic transformation. As organizations have adopted cloud-first strategies and users increasingly rely on web-based applications, the browser has become the dominant workspace and a primary target for attacks. Thus, the attackers who once targeted operating systems and network infrastructure are now focused on identity and session data managed within the browser. This shift has given rise to a new class of threats uniquely engineered to exploit browser environments, often bypassing traditional security tools entirely.

As a result, cyberthreats now increasingly focus on exploiting browser identity artifacts. Browsers have become the primary workspace and therefore the primary target for attacks. Below are the most prevalent attack vectors threatening browser identity today.

NO.	TECHNIQUE
1	Man-in-the-Browser (MiTB) Attacks
2	Credential Theft via Keylogging and Formjacking
3	Session Hijacking and Cookie Theft
4	Malicious Browser Extensions
5	Mail Phishing and Browser-Based Social Engineering
6	Cross-Site Scripting (XSS) and DOM Manipulation
7	OAuth Abuse and Token Impersonation
8	HTML Smuggling
9	Clickjacking and UI Redressing
10	Tabnabbing and Tab Spoofing
11	WebRTC and Browser Metadata Leaks
12	Supply Chain Attacks via JavaScript Dependencies

01 Man-in-the-Browser (MiTB) Attacks

MiTB attacks involve stealthy malware that resides inside the browser, often delivered through phishing or drive-by downloads. Once active, it intercepts web sessions, manipulates page content, and silently captures sensitive data such as login credentials or transaction details — even within HTTPS sessions. These attacks are notoriously difficult to detect because the browser appears to function normally from the user's perspective. The malware operates between the user and the browser interface, effectively bypassing traditional endpoint protections. Without visible indicators or alerts, users continue to interact with compromised sessions, allowing attackers to gain full control over inputs and outputs.

02 Credential Theft via Keylogging and Formjacking

Credential theft is a major problem that users face worldwide. The abuse of valid accounts now represents 32% of cyber incidents.[2] Keyloggers and formjackers target data entered into browser fields, capturing usernames, passwords, and payment details in real time. Keyloggers run in the background and record every keystroke, often embedding themselves deep within the browser or operating system to avoid detection. Formjackers, on the other hand, inject malicious JavaScript into webpages — typically on compromised third-party services — intercepting sensitive input before it is securely transmitted. These scripts are stealthy and often indistinguishable from legitimate code, making them hard to identify with standard security tools. The stolen data is usually transmitted instantly to external servers, enabling attackers to monetize credentials or commit fraud rapidly.

03 Session Hijacking and Cookie Theft

Session hijacking involves intercepting a valid user session to gain unauthorized access to an application. Attackers typically steal session cookies using infostealer malware or cross-site scripting (XSS) exploits, or by intercepting unsecured network traffic. Once they possess a session token, they can impersonate the user without requiring credentials or MFA. These attacks are particularly dangerous because they exploit authenticated sessions, bypassing most identity verification systems. The result can be full account compromise and unauthorized actions performed under the user's identity. Sophisticated attackers may even automate token replay or inject commands into active sessions, allowing them to conduct transactions, alter user data, or escalate privileges undetected. Traditional security solutions often lack visibility into these real-time browser-level events, making session hijacking a critical blind spot for many enterprises.

04 Malicious Browser Extensions

Browser extensions, especially those with excessive permissions, can become a serious identity threat. Malicious or hijacked extensions can harvest session cookies, authentication tokens, saved credentials, and autofill data, directly undermining browser-based identity mechanisms. These extensions often request access to all websites and user input, enabling them to operate across multiple login portals and authentication flows. Attackers frequently exploit weak vetting processes in extension marketplaces to deploy these threats, sometimes repurposing previously trusted extensions after acquisition. Because they operate within the trusted user interface (UI) of the browser and are rarely monitored by endpoint or identity protection tools, these extensions can silently compromise user sessions, leading to unauthorized access and identity impersonation across cloud services.

[2] IBM, X-Force Threat Intelligence Index 2026

05 Mail Phishing and Browser-Based Social Engineering

Modern phishing campaigns have evolved beyond email deception to include browser-based tactics that exploit user trust and browser interfaces. Adversary-in-the-Middle (AiTM) phishing proxies intercept credentials and session tokens during the login process, even after MFA is completed. These proxies mimic legitimate login pages and often utilize valid SSL certificates, making them indistinguishable to end users. Meanwhile, social engineering strategies such as MFA fatigue and fake browser alerts trick users into surrendering sensitive information or authorizing unauthorized actions. AI-generated messages and spoofed branding further increase the credibility of these threats. These methods bypass traditional security filters, resulting in full session takeovers that can lead to identity theft and unauthorized access to corporate resources. The browser becomes the vector for compromise, reinforcing the need for proactive, identity-aware controls that operate at the browser layer.

06 Cross-Site Scripting (XSS) and DOM Manipulation

XSS remains a prevalent vulnerability exploited to execute arbitrary scripts within a user's browser. Once executed, attackers can steal session cookies and OAuth tokens, or manipulate DOM elements to present spoofed login fields. DOM-based XSS variants are particularly dangerous, as they never touch the server, making them invisible to traditional web application firewalls (WAFs) and back-end scanners. These attacks are frequently used to escalate access or perform session hijacking.

07 OAuth Abuse and Token Impersonation

Modern applications use OAuth tokens for delegated access. Attackers exploit misconfigured OAuth flows and insecure storage of access tokens, or trick users into granting permissions to rogue applications via malicious OAuth consent phishing. Since OAuth tokens can grant long-lived access without needing credentials or re-authentication, this vector is ideal for persistent, stealthy impersonation, especially in cloud apps like Google Workspace and Microsoft 365.

08 HTML Smuggling

In HTML smuggling, malicious scripts are embedded within HTML pages and executed locally in the browser. This technique bypasses network defenses, such as proxies and secure web gateways (SWGs), because no file is downloaded in a conventional manner. HTML smuggling is often used to stage more complex attacks, such as deploying infostealers or remote access trojans that harvest credentials and cookies from browser memory or storage.

09 Clickjacking and UI Redressing

Clickjacking deceives users into clicking on invisible or disguised elements layered within legitimate pages (e.g., "Confirm" or "Login" buttons), tricking them into unintentionally performing actions such as granting permissions or authorizing malicious apps. Such attacks exploit the trusted nature of the browser interface and can result in unauthorized changes, elevation of access privileges, and unauthorized transactions linked to identities.

10 Tabnabbing and Tab Spoofing

Tabnabbing manipulates inactive browser tabs to load lookalike login pages when the user is not looking. When the user returns to the tab, they are prompted to re-authenticate on a spoofed interface, unaware that their credentials are being stolen through phishing. This low-tech but highly effective tactic exploits user behavior and browser tab trust assumptions, often bypassing technical controls entirely.

11 WebRTC and Browser Metadata Leaks

Even when users rely on VPNs, WebRTC APIs can leak real IP addresses due to STUN requests, enabling de-anonymization. Similarly, browser fingerprinting via metadata, such as screen size, time zone, fonts, and installed plugins, can enable persistent tracking across sessions and identities — even without cookies. These are often exploited for surveillance, targeted attacks, or correlating accounts across platforms.

12 Supply Chain Attacks via JavaScript Dependencies

Third-party JavaScript libraries and software development kits (SDKs) integrated into web apps can be compromised at the source or injected during build pipelines (e.g., dependency confusion). Once loaded in a browser context, these scripts inherit full trust and access within the domain, allowing attackers to exfiltrate identity artifacts or inject credential-stealing mechanisms that are nearly impossible to distinguish from legitimate code.

Why Legacy Security Tools Fall Short

Over the past 20 years, enterprise security has evolved from a focus on firewalls and antivirus solutions to a layered defense strategy that includes identity and access management (IAM) and SWGs. In the early 2000s, security tools were largely perimeter-based, designed to keep threats outside the corporate network. As enterprises adopted mobile workforces, cloud services, and bring-your-own-device (BYOD) policies, the traditional perimeter began to dissolve.

Identity emerged as the new security boundary, and browsers became the primary interface for digital work. However, most legacy tools were not designed to protect identity at the browser level, leaving organizations exposed to a new wave of sophisticated, browser-native attacks.

Antivirus (AV)

AV solutions focus on identifying known malware using signatures and heuristic analysis. However, modern browser threats often employ fileless techniques, such as in-browser JavaScript attacks, token theft via browser extensions, and form manipulation, which circumvent these traditional detection methods.

Cloud Access Security Brokers (CASBs)

While CASBs are valuable for managing sanctioned SaaS usage, they operate via API inspection or reverse proxy and cannot detect malicious behavior occurring directly inside the browser. They are blind to DOM-based attacks, token exfiltration, clipboard manipulation, and credential theft in real time.

Identity Providers (IdPs) and Multifactor Authentication (MFA)

IdPs control who gets in, but not what happens after login. MFA sessions can be compromised by phishing proxies that steal the resulting session cookies. IdPs offer no visibility into misuse of authenticated sessions, browser behavior, or in-session anomalies.

Secure Email Gateways (SEGs)

SEGs are designed to block malicious emails, but once a user clicks on a link, their role ends. They provide no visibility or enforcement capabilities within the browser, allowing phishing websites to bypass protections with AiTM techniques and harvest credentials undetected.

Static Browser Protections

Standard browsers rely on sandboxing, Content Security Policy (CSP) policies, and URL reputation blocklists to mitigate threats. However, they do not assess page behavior in real time or flag malicious activity embedded in dynamic JavaScript or malicious DOM changes. For example, a phishing page hosted on a newly registered domain with a valid SSL certificate will not be blocked until it is added to a blocklist, leaving a vulnerability window where identity data can be stolen. Additionally, users are expected to recognize deceptive cues, which is an unreliable strategy against highly sophisticated threats.

Network Controls Are Insufficient

Encrypted protocols like TLS 1.3 and DNS-over-HTTPS (DoH) protect user privacy but also obscure malicious activity from traditional perimeter defenses. SWGs and proxies often struggle to decrypt and inspect traffic due to performance, privacy, or technical limitations, particularly in BYOD and remote work environments. Attackers exploit this blind spot by using HTTPS for phishing kits, command-and-control servers, and data exfiltration routes, making browser-layer visibility essential for identity threat detection and prevention.

As the browser becomes the nexus of enterprise identity and access, it has simultaneously become the most under-defended component in the security stack. The modern threat landscape is defined by stealthy, browser-resident attacks that evade traditional tools and operate within trusted sessions and user interfaces. Legacy solutions, whether endpoint-based, network-based, or identity-focused, are simply not equipped to address threats that unfold entirely within the browser. Addressing this blind spot requires a fundamentally new approach, one that embeds security in the browser layer itself.

A New Approach: Browser-Native Security with Falcon Seraphic Enterprise Browser

Falcon Seraphic Enterprise Browser introduced a patented browser-agnostic solution that injects a lightweight but powerful security control plane directly into any browser — Chrome, Edge, Firefox, Safari, and agentic browsers — without forcing organizations to adopt a new browser ecosystem. This embedded control layer makes each browser security-aware, allowing it to enforce policies and detect threats in real time, even on unmanaged devices.

In-Browser Telemetry and Policy Enforcement

Falcon Seraphic Enterprise Browser enables deep telemetry by inspecting browser-layer events such as DOM manipulation, JavaScript execution, input field interaction, and credential usage. Unlike traditional endpoint and network tools, this telemetry is identity-aware and context-sensitive. Administrators can define granular policies to control user actions per site, such as disabling copy-and-paste on sensitive fields, blocking unauthorized file downloads, and restricting access to login portals. Falcon Seraphic Enterprise Browser monitors hundreds of runtime parameters in the JavaScript engine and evaluates them continuously to detect anomalous or malicious behavior.

Data Encryption and Identity Artifact Protection

One of Falcon Seraphic Enterprise Browser's most critical differentiators is its ability to encrypt browser-resident identity artifacts, including cookies, tokens, and local storage data. Even if an attacker gains access to the device or browser profile, these encrypted items are unreadable and unusable outside the Falcon Seraphic Enterprise Browser-enhanced session. This defeats common attack techniques, such as token theft via infostealers or malware, and renders stolen session cookies ineffective. It also protects against lateral movement by ensuring that identity tokens cannot be replayed or exfiltrated across environments.

Real-Time Phishing Detection and Prevention

Falcon Seraphic Enterprise Browser's breakthrough approach embeds its protection natively within the browser's JavaScript engine, allowing it to detect and neutralize phishing attacks that evade traditional controls such as SWGs, email filters, and threat intelligence feeds. Unlike solutions that rely on static site classifications or retrospective indicators of compromise, Falcon Seraphic Enterprise Browser leverages behavioral signals and real-time telemetry to dynamically assess risk. This enables Falcon Seraphic Enterprise Browser to identify malicious websites, including those hidden behind obfuscation tactics like CAPTCHAs, redirects, or cloaked URLs, and neutralize them before users engage. Risky pages are rendered in read-only mode, preventing the input of credentials and data submission. Augmenting its telemetry with AI-driven behavioral analytics, Falcon Seraphic Enterprise Browser dynamically analyzes page structure, JavaScript behavior, and user interaction patterns to detect phishing, even when hosted on legitimate domains or created moments before use. It proactively blocks advanced identity threats, such as HTML smuggling, session hijacking, and cookie theft, and stops AiTM techniques used in tools like EvilProxy, Modlishka, and Evilginx. Falcon Seraphic Enterprise Browser provides enterprise-grade browser-native protection proven to stop zero-hour phishing attacks at execution time, before they can succeed.

Browser-Native Zero Trust Enforcement

Falcon Seraphic Enterprise Browser integrates with enterprise IdPs, such as Okta and Azure AD, to bind policies to user identity and role. This enables context-aware enforcement, such as permitting full access for employees on managed devices and read-only access for contractors, and blocking access entirely for unknown users. Each browser session becomes a controlled perimeter, aligning with Zero Trust principles.

Defense Against Related Identity-Based Attacks

Falcon Seraphic Enterprise Browser actively defends against a broad range of browser-borne identity threats, including session hijacking, HTML smuggling, XSS, and AiTM phishing. Its runtime protection mechanisms block exploit techniques before they can execute, thereby neutralizing attack paths used to extract session tokens or impersonate users. These protections are designed to operate in real time, without relying on traditional threat feed updates or cloud sandboxing.

Universal Coverage and Privacy Respect

Whether on managed corporate endpoints or personal devices, Falcon Seraphic Enterprise Browser offers unified protection and policy enforcement. It extends identity security to third parties, affiliates, and contractors without requiring device enrollment. For personal devices, Falcon Seraphic Enterprise Browser Workspace ensures Seraphic Enterprise Browser to enterprise resources while maintaining a clear boundary between work and personal browsing, preserving user privacy.

Tangible Business Benefits

Prevent Account Takeovers

Falcon Seraphic Enterprise Browser's identity-aware browser security prevents unauthorized access by intercepting session hijacking attempts, credential theft, and token exfiltration in real time. By encrypting authentication materials, such as cookies and session tokens, and blocking phishing attempts at the browser layer, it prevents attackers from impersonating users, even if credentials are compromised.

Reduce Incident Response Workload

With real-time detection and prevention built into the browser, many identity threats are neutralized before reaching security operations. This drastically reduces alert noise, false positives, and the volume of incidents requiring triage. SOC teams gain browser-layer telemetry, enabling faster forensic investigation and response.

Enhance Regulatory Compliance

Falcon Seraphic Enterprise Browser supports compliance with data protection and privacy regulations (e.g., GDPR, HIPAA, SOX) by enforcing granular access controls, encrypting sensitive data, and preventing credential reuse. Policies can be tailored to protect personally identifiable information (PII) and provide appropriate access control based on user identity, role, device posture, and session context.

Secure Remote and Third-Party Access

Falcon Seraphic Enterprise Browser extends enterprise-grade protections to unmanaged devices and third parties without requiring full device management. This is especially critical for BYOD environments, contractors, and external collaborators. It enables secure access while respecting personal privacy boundaries.

Support Zero Trust Strategies

By turning the browser into a context-aware security enforcement point, Falcon Seraphic Enterprise Browser aligns with Zero Trust architectures. Each session is continuously evaluated, and access is governed based on identity, risk, and environment, making it ideal for modern, decentralized workforces.

Next Steps

Web browsers are the new perimeter of identity. As threats evolve, enterprises must adopt browser-native defenses that go beyond traditional network controls. Falcon Seraphic Enterprise Browser delivers this capability, providing real-time protection, deep visibility, and adaptive policy enforcement where it matters most: the browser.

If your workforce lives in the browser, your security must live there too. Request a demo at www.crowdstrike.com/en-us/contact-us/ to see how Falcon Seraphic Enterprise Browser turns your browser into a secure workspace.

About CrowdStrike

CrowdStrike (Nasdaq: CRWD), a global cybersecurity leader, has redefined modern security with the world's most advanced cloud-native platform for protecting critical areas of enterprise risk — endpoints and cloud workloads, identity and data.

Powered by the CrowdStrike Security Cloud and world-class AI, the CrowdStrike Falcon® platform leverages real-time indicators of attack, threat intelligence, evolving adversary tradecraft and enriched telemetry from across the enterprise to deliver hyper-accurate detections, automated protection and remediation, elite threat hunting and prioritized observability of vulnerabilities.

Purpose-built in the cloud with a single lightweight-agent architecture, the Falcon platform delivers rapid and scalable deployment, superior protection and performance, reduced complexity and immediate time-to-value.

CrowdStrike: We stop breaches.

Learn more: https://www.crowdstrike.com/

Follow us: Blog | X | LinkedIn | Facebook | Instagram

Start a free trial today: https://www.crowdstrike.com/free-trial-guide/

© 2026 CrowdStrike, Inc. All rights reserved.